What Redaction Left Behind in 200 Synthetic Patient Calls

After a simulated redaction at threshold 0.4, in the spoken-form transcripts, 60 of the 80 scripted calls that held a complete fake-invoice kit still held it under RAGLeakGuard 0.1.1 (the tested source installation); 0 of 80 under Presidio's default configuration. Counts of what remained, so lower is better.

Wen-Chia “Belle” Chang · Agenvana

All patient data synthetic · all methods open-source and reproducible

We built two synthetic stores, a 2,000-note dental-clinic knowledge base and 200 scripted receptionist calls, ran two open-source PII scanners over them, masked what each flagged, and counted what each record still showed afterwards. The results are synthetic exposure measurements, not proof of fraud. Measured, not guessed.

THE ONE FINDING

An electricity bill arrives by email. The PDF looks right: the logo, the layout, the account summary, the due date. The amount is about what the last one was. People pay it.

A month or two later the real power company writes: *you have not paid in two months.* The first payment went to someone else, and it is gone.

The people who paid were not careless. If the reference number on your real bills changes from one bill to the next, a new reference number is not a warning sign; it is what a bill looks like. The logo was the real logo. Nobody ever told them the logo could lie. The scam worked because it was built out of the exact trust cues the system had trained them on.

What does a fake bill draw on? Australia's National Anti-Scam Centre puts it plainly in its fake-invoice alert: scammers "pose as a real business you've recently dealt with" and make the invoice look real by copying logos and ABNs. After the Optus and Medibank breaches, Scamwatch warned that scammers "will use the data breach and target people in any way that they can." Where the details behind any one fake bill came from, nobody outside the investigation can say, and this report does not claim to.

So we asked the one part of the question we could measure. Businesses that run AI assistants over their records are told to redact personal information before the records are stored or embedded. We built two synthetic stores, a 2,000-note dental-clinic knowledge base and 200 scripted receptionist calls, ran two open-source PII scanners over them, masked what each flagged, and counted what each record still showed afterwards. For this test we defined a **strict kit** as four retained fields, all still readable after the mask: a full name, a contact channel, the provider, and a particular appointment cue. That is an operational definition of what remained, not a demonstration that anyone could carry out a fraud with it.

Read the kit counts this way: they count exposure left behind, so a larger number means less was masked, and a zero is not safety.

Under Presidio's default configuration, 0 of the 357 synthetic notes and 0 of the 80 scripted calls that held a kit kept it, in every text rendering, because its date recogniser masks every appointment cue; other sensitive details can remain in those records.

Under RAGLeakGuard, the tested source installation of our own open-source tool, 13 of 357 notes still held the whole kit, and in the spoken-form transcripts, 60 of 80 calls did.

In that spoken-form rendering, a full name and a contact channel were both still readable in 42 of 200 calls under Presidio default, and in 156 of 200 under RAGLeakGuard. Clinic counts assume the provider is known from the database the note sits in.

These are synthetic records and a simulated redaction. Nothing here shows a scam succeeding, and a record that lost its kit is not thereby safe. What the numbers show is narrower and, for anyone who has written "we redact PII" into a compliance document, more useful: what a redaction leaves behind depends on the tool and its configured pipeline and on the shape of the text, and, in the four configurations we tested, the details that would make a bill feel like yours (the complaint, the plan, a billing cue) were left intact far more often than the identifiers were.

EXECUTIVE SUMMARY

The one page to read

What we did. Three things, with a reviewed reproducibility export published alongside the report so anyone can check them. **First**, a measurement: we took the 2,000-record synthetic Australian dental-clinic knowledge base from Issue #2 and the 200 scripted receptionist calls from Issue #3 (a mixed roster of 100 Australian and 100 US synthetic patients built from the public Synthea generator, each call in three scripted text shapes: formatted, digits, spoken), ran four scanner configurations over them (Microsoft Presidio with stock defaults; Presidio with its optional Australian recognisers switched on; RAGLeakGuard, our own open-source tool, in its default and `--locale au` configurations, from source commit `47dedfe` in an environment that satisfies its declared pins), masked every finding at or above the actionable score of 0.4, and counted what each record still showed. No real person's data was used anywhere. **Second**, a definition: for this test a "fake-invoice kit" is an operational definition of retained fields, a full name, at least one contact channel, the provider, and a particular appointment cue or an amount, all still readable after the mask (the strict tier; no synthetic record carries an amount, so the tier turns on the appointment cue). It measures what remained, not whether anyone could defraud anyone with it. We also report the "deliverable" tier (name plus a contact channel) and, element by element, what survived. **The kit and intact-element counts in this report are exposure left after the mask: on those counts lower is better, and zero is not safety.** (Denominators, removed and partial counts and the public statistics are not exposure counts and carry no such direction.) **Third**, the public record: the 2025 scam and breach statistics of Australia's National Anti-Scam Centre, the FBI's Internet Crime Complaint Center, the US Federal Trade Commission and the Office of the Australian Information Commissioner, quoted as printed with access dates, and the official statements that connect breached data to targeted scams.

What we found.

- **The lead: after simulated redaction of synthetic notes and scripted calls, Presidio default left 0 of 357 clinic notes and 0 of 80 calls with an intact strict kit in every rendering; RAGLeakGuard 0.1.1, the tested source installation, left 13 of 357 notes (provider assumed from database context) and, in the spoken rendering, 60 of 80 calls. Counts of what remained; lower is better.** These are counts of what remained, so the larger number is the larger exposure on this measure. On these fixtures, the tested Presidio configurations left fewer intact strict kits and fewer records retaining both a full name and a contact channel than the tested RAGLeakGuard configurations. This is not an overall product ranking: RAGLeakGuard itself builds on Presidio with a different language model, extra patterns and a filter, so this is a comparison of two configured pipelines on these fixtures, and no precision, utility or production benchmark was run. Presidio's date recogniser removes every appointment cue ("next Tuesday" in all 357 notes; every annotated appointment slot in the 80 booking and reschedule calls, such as "tuesday 1015"), which breaks the strict kit even where the name and a contact channel survive. RAGLeakGuard's date post-filter drops these appointment phrases because they do not match its retained date patterns (a separated numeric fragment or a month-name prefix, at the measured commit), so every appointment cue survives (357 of 357 notes; 80 of 80 calls), and in the spoken-form transcripts, where no configuration recognised a spoken phone number as a phone number, 60 of the 80 calls that held a kit still held the whole of it (booking 24 of 40, reschedule 36 of 40). Records with a full name and a contact channel both still readable in the spoken rendering: 42 of 200 under Presidio default, 156 of 200 under RAGLeakGuard. In the formatted rendering both tools left 0 and 1 of 200 such records. Presidio's zero on the strict tier comes from masking the appointment cue; the 42 records above show that other sensitive details remained. Clinic counts assume the provider from database context.
- **Supporting finding, the setting: Presidio's default configuration left all or part of a Medicare number in 376 of 2,000 synthetic clinic notes (221 complete, 155 partial); with its Australian recognisers switched on, 0; RAGLeakGuard, the tested source installation, left 390 complete**

(threshold 0.4). Presidio ships its Australian recognisers disabled. In the default configuration the Medicare spans were touched only by other recognisers (phone-number and date guesses, and three person-name overlaps), which is why 221 numbers stayed complete and 155 were only partly covered. One configuration change removed 2,000 of 2,000. RAGLeakGuard's own Medicare pattern did not match the standard spaced format, so its only label on those spans was a phone-number guess and 390 stayed complete. That is the runnable check in §6, and it names our own tool's gap in the same breath.

- **Supporting finding, the credibility half: after simulated redaction, the annotated credibility details present in a note (the clinical or service context, an appointment or interval cue, a billing cue; provider assumed from database context) were all still fully intact in 2,000 of 2,000 synthetic clinic notes under RAGLeakGuard 0.1.1, the tested source installation, and in 1,071 of 2,000 under Presidio default.** The same configurations left a complete name in 359 and 12 of those notes respectively, so this is not a story about names being removed; it is a story about what the four tested configurations do not have a recogniser for: a complaint, a treatment, a billing cue ("payment plan", "health care card", "cost grounds"), a provider. Presidio's date recogniser does mask the appointment and interval cues, and both frameworks accept added recognisers, so this is a statement about the tested configurations, not about what a scanner can be made to do. Those details are the kind that make a bill feel like yours, and clinical context tied to a named person is personal information whether or not a recogniser targets it.
- **The public record, as context.** Australians made 481,523 scam reports in 2025 across the combined national datasets, 274,577 with a financial loss, totalling A$2.18 billion in reported losses; payment-redirection scams (the fake-invoice redirection) accounted for A$166.8 million of them. The FBI's IC3 logged 1,008,597 complaints and US$20.877 billion in reported losses in 2025 (its report includes some international submissions), including 67,456 "personal data breach" complaints and US$3.05 billion in business email compromise losses. In the latest Australian breach statistics (July to December 2025), contact information was involved in 537 of 670 notified breaches, the most common kind, and health service providers were the most affected sector. Sources, pages and access dates are in §3.5.

Why this matters to your business. If your organisation has written "we redact personal information before storing or embedding it" into a privacy policy, a procurement answer or a board paper, this report is about the gap between that sentence and what a redaction does. In our synthetic test, the difference between 0 and 60 complete kits still readable out of 80 scripted spoken-form calls was not the organisation's intent. Within the scripted spoken-form rendering, the two tested pipelines (language model, patterns and filters together) left 0 and 60 of 80 strict kits intact. Separately, RAGLeakGuard's own count differed across the three scripted text renderings (0, 12 and 60 of 80), which change casing, punctuation and number words at once and were not a controlled test of one transcription setting; within each tool, switching its Australian recognisers on or off changed no kit count, and what that switch did change was the Medicare column. A clinic, a law firm or a broker whose AI assistant keeps a copy of every intake note or call may hold a store in which, after a standard redaction, the credibility details a record carries (its complaint; an appointment cue where there is one; a billing cue where there is one) are all still intact: in our fixture that was 2,000 of 2,000 notes under RAGLeakGuard and 1,071 of 2,000 under Presidio default, with the provider assumed from database context. If convincing invoices ever reach your customers, an investigation may examine the stores that held their details, and "we run a PII scan" is a sentence that would have to survive the question "which one, configured how, on text written how?"

The good news, and it is real. Some measured exposures changed substantially with configuration or text rendering, and some did not. One recogniser switch took the 376 synthetic notes with all or part of a Medicare number still readable (221 complete, 155 partial) to 0. In formatted text, both tools' redaction left no complete strict kit and at most one record in 200 with a full name and a contact channel both readable. The appointment cue survived under RAGLeakGuard because its date filter drops it. The billing cues

remained intact wherever present under every tested configuration, and the clinic service context remained fully intact in 1,601 notes under Presidio default and 2,000 under RAGLeakGuard, with the other 399 partly covered under Presidio by its date recogniser; none of the four configurations carries a recogniser for a complaint or a billing cue, and both frameworks accept added recognisers, so the gap is a configuration and design question as much as a tooling one. Two things follow: check what your redaction leaves behind before you call it done, and decide what a free-text record needs to hold at all. Section 6 is the list, and its first item is a check you can run in a few minutes on your own machine.

If you commission or build AI systems that handle sensitive records, I can help you review what your safeguards actually leave exposed.

THE FINDING

What the mask left behind: by tool, by configuration, by text shape

3.1 Strict kits still readable after simulated redaction of synthetic notes and scripted calls (lower is better): Presidio default 0 of 357 notes and 0 of 80 calls; RAGLeakGuard 0.1.1, the tested source installation, 13 of 357 notes (provider assumed from database context) and, spoken, 60 of 80 calls

The question, and how to read the numbers. The kit and intact-element figures in this section count what was still readable after the mask: a larger number is more remaining exposure on that measure, not better detection, and a zero means only that no record kept the defined combination. For this test we defined four retained fields a fake invoice could draw on: a full name, a channel to deliver it, the provider it pretends to come from, and a credibility detail. We defined the **strict kit** as all four still readable after the mask, with the credibility detail restricted to a particular appointment cue or an amount (no synthetic record carries an amount, so the tier turns on the appointment cue: the spoken slot such as "Tuesday 10:15" in the booking and reschedule calls, and the plan line "next Tuesday" in the clinic notes). Only the 357 notes and the 80 calls that hold such a cue can hold a strict kit at all, so every strict figure is "of 357" or "of 80". A service interval ("a review in three months") does not qualify.

Synthetic clinic notes, 2,000 records, strict kits still complete after the mask (the 357 possible are the notes whose plan line says "next Tuesday"):

Configuration	Deliverable (name + a contact channel)	Core, strict (of 357 possible)
Presidio stock defaults	1 / 2,000	**0** / 357
Presidio, AU recognisers on	1 / 2,000	0 / 357
RAGLeakGuard default (source commit `47dedfe`)	80 / 2,000	**13** / 357
RAGLeakGuard `--locale au`	80 / 2,000	13 / 357

Clinic counts assume the provider is known from database context (one clinic's knowledge base); a complete kit here is a complete kit *given* that context, what a reader with access to the store could assemble, not what one note contains on its own. Simulated redaction at threshold 0.4 on the generated note text.

Scripted calls, 200 records in three text renderings, strict kits still complete after the mask (the 80 possible are the booking and reschedule calls, 40 + 40, the only scenarios that carry a slot):

Rendering	Configuration	Deliverable (of 200)	Core, strict (of 80)
formatted	Presidio default and AU on	0	0
formatted	RAGLeakGuard (both)	1	0
digits	Presidio default and AU on	24	0
digits	RAGLeakGuard (both)	82	12
spoken	Presidio default and AU on	**42**	**0**
spoken	RAGLeakGuard (both)	**156**	**60**

Per scenario, the 60 strict kits under RAGLeakGuard in the spoken rendering are booking 24 of 40 and reschedule 36 of 40. Presidio left 0 in every scenario and rendering because its date recogniser removed or partly covered every slot: in the spoken rendering every annotated appointment slot (five slot strings across the 80 booking and reschedule calls, "tuesday 1015" among them) was labelled as a date (45 removed, 35 partial, 0 intact).

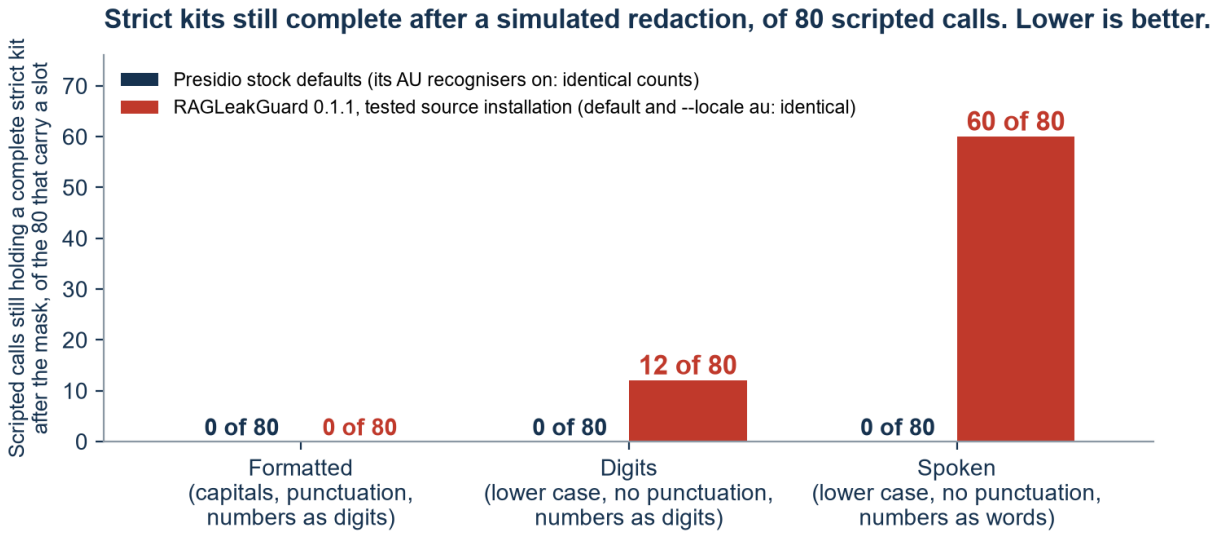
Why the two tools diverge, in one sentence each. Presidio's date recogniser treats "next Tuesday" and "tuesday 1015" as dates and covers them, which breaks the strict kit even where it left the name and a contact channel. RAGLeakGuard's date post-filter drops these appointment phrases because they do not match its retained date patterns (at the measured commit, a separated numeric fragment or a month-name prefix), so the appointment cue survives in 357 of 357 notes and 80 of 80 calls. That describes the observed mechanism; the experiment does not judge whether suppressing such phrases is appropriate for a PII tool.

Why the spoken rendering is where the kits survive. In the spoken-form transcripts ("oh four six three one five nine eight five four"), no configuration recognised a spoken phone number as a phone number: Presidio's only labels on them were date guesses (66 overlaps, the Issue #3 result again) and RAGLeakGuard put no label on them at all, so every one of the 200 spoken phone numbers stayed intact under RAGLeakGuard and 134 of 200 under Presidio default. Names are the other half: in the spoken rendering RAGLeakGuard left 156 of 200 names intact (10 partial, 34 removed) against Presidio default's 50 (20 partial, 130 removed). Model size and version differ between the two configurations by design (§4), so the name column is a comparison of tested configurations, not of models.

Element by element, spoken rendering (intact / partial / removed; "present" is how many of the 200 calls carry the element).

Element (present)	Presidio default and AU on (identical)	RAGLeakGuard (both configurations)
Name (200)	50 / 20 / 130	156 / 10 / 34
Phone (200)	134 / 66 / 0	200 / 0 / 0
Email (120)	44 / 76 / 0	106 / 14 / 0
Address (80)	20 / 60 / 0	51 / 29 / 0
Date of birth (200)	12 / 60 / 128	25 / 39 / 136
Medicare (40)	20 / 20 / 0	40 / 0 / 0
US Social Security number (19)	0 / 19 / 0	19 / 0 / 0
Insurance ID (21)	14 / 7 / 0	21 / 0 / 0
Appointment slot (80)	0 / 35 / 45	80 / 0 / 0
Any contact channel intact	150	200
Provider (the clinic name, spoken in every call)	200 intact	200 intact

The spoken emails survive because the generator verbalises them ("kirk dot reinger three four at bigpond dot com"), a shape the email recogniser does not match. The three renderings are scripted text shapes that change casing, punctuation and number words at once; they are not a controlled experiment on one speech-to-text setting, and no audio was transcribed.



Synthetic calls; simulated redaction at threshold 0.4 (a character mask over every finding at or above it). Strict kit = a full name, a contact channel, the clinic name and the appointment slot all still readable. Counts of what remained, so lower is better, and 0 is not safety: Presidio's zero comes from its date recogniser masking every slot while other details can remain. RAGLeakGuard 0.1.1 from source commit 47dedfe; Presidio stock defaults. The three renderings are scripted text shapes, not one speech-to-text setting.

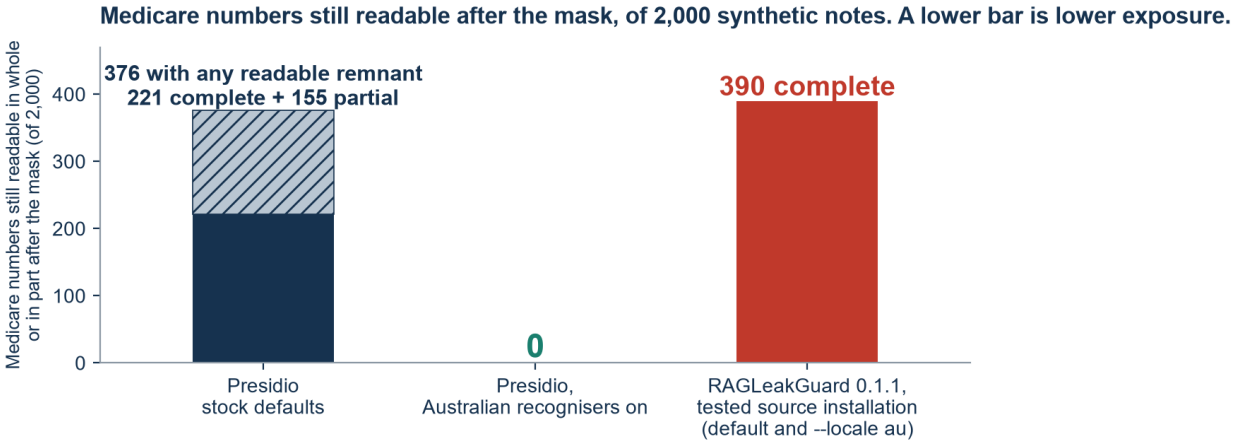
3.2 The setting: Presidio default left all or part of a Medicare number in 376 of 2,000 synthetic clinic notes (221 complete, 155 partial); its Australian recognisers, switched on, left 0; RAGLeakGuard, the tested source installation, left 390 complete (threshold 0.4; counts of what remained)

Presidio ships Australian recognisers (Medicare, TFN, ABN, ACN) with `enabled: false` in its default configuration since v2.2.359. In the default configuration, then, nothing in the engine is looking for a Medicare number. The 2,000 Medicare spans in the synthetic notes were touched only by recognisers looking for something else: the actionable findings overlapping them carried the labels `PHONE_NUMBER` (1,610 overlaps), `DATE_TIME` (902) and `PERSON` (3). Overlaps are not disjoint records. The result per element: **221 of 2,000 Medicare numbers stayed complete and 155 were only partly covered**, 376 notes with all or part of the number still readable; 1,624 were removed, almost all because the number was taken for a phone number at score 0.4, the actionable floor.

With the optional Australian recognisers switched on (the configuration also enables the other AU recognisers and an AU-aware phone recogniser), `AU_MEDICARE` fired on all 2,000 and **0 of 2,000** survived in any state.

RAGLeakGuard, the tested source installation, has its own Medicare pattern, and it did not fire on this fixture's spaced format ("4655 04518 5"). Its only label on those spans was `PHONE_NUMBER` (1,610 overlaps) and **390 of 2,000 stayed complete**, 0 partial. In the spoken rendering of the calls, RAGLeakGuard left all 40 spoken Medicare numbers, all 19 spoken Social Security numbers and all 21 insurance IDs intact; Presidio default's date guesses partly covered 20, 19 and 7 of them. Our tool's gap is recorded for review in the product backlog, not fixed in this cycle, and nothing in the product repository changed.

This is a configuration result on one fixture, measurable before and after on a single synthetic note, which is why it is the runnable check in §6. It is not a failure of an enabled recogniser and not a production privacy guarantee.



2,000 synthetic clinic notes, simulated redaction at threshold 0.4. Counts of numbers still readable in whole or in part, so a lower bar is lower exposure on that definition; the partial component (hatched) has no direction of its own and always travels with the complete component. One setting, Presidio's optional Australian recognisers, took the column to 0; our own tool's Medicare pattern did not match the spaced format and its tested installation left 390 complete.

3.3 The credibility half: after simulated redaction of 2,000 synthetic clinic notes, all annotated credibility details present in each note remained intact in 1,071 notes under Presidio default and 2,000 under RAGLeakGuard 0.1.1, the tested source installation (provider assumed from database context)

We annotated four credibility details a fake bill could cite: the clinical or service context (the complaint or treatment the visit is about), an appointment cue, a service interval, and a billing cue such as "payment plan", and we assumed the provider from database context. Not every note holds every cue: 357 hold an appointment cue, 478 an interval cue, 648 a billing cue, and all 2,000 a service context. The annotated details are these four, not everything that could make a bill believable.

Element (of 2,000 unless stated)	Presidio default (intact / partial / removed)	RAGLeakGuard, both configurations
Name	12 / 27 / 1,961	359 / 30 / 1,611
Address	327 / 1,673 / 0	462 / 1,538 / 0
Clinical or service context	1,601 / 399 / 0	2,000 / 0 / 0
Appointment cue "next Tuesday" (of 357)	0 / 0 / 357	357 / 0 / 0
Interval cue (of 478)	0 / 307 / 171	478 / 0 / 0
Billing cue (of 648)	648 / 0 / 0	648 / 0 / 0
Provider (database context)	2,000 intact	2,000 intact
Notes in which every present, annotated credibility element is intact	**1,071**	**2,000**

Under RAGLeakGuard, every annotated credibility detail present in a note stayed fully intact in 2,000 of 2,000 notes. Under Presidio default, in 1,071 of 2,000: its date recogniser removed "next Tuesday" in all 357 notes that had it, touched the interval cue in all 478, and partly covered the service span in the 399 notes whose complaint contains a time word (the two templates "attended for a six-month scale and clean", 207 notes, and "reported grinding at night, discussed a splint", 192 notes, both flagged as dates; the other eight complaint templates are intact in every note). The billing cue stayed intact in both tools' tested configurations in all 648 notes that carry one.

The name totals are separate from the credibility counts and they matter: complete names remained in 12 notes under Presidio default and 359 under RAGLeakGuard across the full fixture, so the delivery half of the kit was mostly, not entirely, broken. Addresses were fully intact in 327 and 462 notes. None of the four tested configurations carries a recogniser for a provider name, a complaint or a billing cue; that is a statement about these four configurations on this fixture, not about PII scanners in general. And clinical

context tied to a named person is personal information whether or not a recogniser targets it.

What the redacted records look like. `PT-00049`, the Issue #2 synthetic patient, as Presidio default left the note (the full stored record, rewrapped for display):

```
Patient <PERSON> (DOB <DATE_TIME>, Medicare <PHONE_NUMBER>) reported pain on biting, suspected
cracked cusp. Contact <PHONE_NUMBER> or <EMAIL_ADDRESS|URL>. Address on file: 157 High St,
Norwood SA 5067. Declined treatment on cost grounds; note for follow-up call.
```

The Medicare number went because the tool took it for a phone number (score 0.4, the floor). The address, the complaint and the billing cue stayed. RAGLeakGuard `--locale au` on the same note: identical shape, `<AU_PHONE>` for the mobile, the Medicare number again removed as `<PHONE_NUMBER>` at 0.4, the address again intact.

`CALL-004`, the billing call, spoken rendering, an excerpt as Presidio default left it (opening and closing turns omitted):

```
caller i got a bill i dont understand noella <LOCATION> <DATE_TIME>
agent ill look that up can you confirm your medicare number
caller six five four two six four two nine zero two and the address on the bill is wrong it
should be <DATE_TIME> given tce newtown nsw two oh four two
agent updated what was the bill for
caller the visit about my high blood pressure im on atenolol now send the corrected bill to
noella dot <LOCATION> <DATE_TIME> at hotmail dot com and ring me on oh four six three one five
nine eight five four if theres a problem
```

The surname was flagged as a location, the house number and the digits in the email as dates; the Medicare number, the callback number, the suburb, the condition, the medication and the bill itself stayed. The name here is *partial* (first name visible, surname covered), so this call does not count as deliverable. RAGLeakGuard `--locale au` on the same call removed the full name as `<PERSON>`, partly covered the spoken date of birth and the surname inside the spoken email, and left the Medicare number, the callback number, the address, the condition, the medication and the bill as spoken.

3.4 What survived together: identifiers still intact per record

Of the six identifier elements every synthetic note carries (name, phone, email, address, date of birth, Medicare number), Presidio default left 0 of 6 intact in 1,476 notes, 1 in 488 and 2 in 36; RAGLeakGuard left 0 in 1,020, 1 in 761, 2 in 207 and 3 in 12. The artifacts hold these histograms as aggregates, not a per-record cross-tabulation, so how the 12 notes with three identifiers intact overlap the 80 deliverable notes or the 13 strict kits is not recorded and is not claimed here. The point of the per-record view is the one a per-element summary hides: marginal counts do not show co-occurrence. In our synthetic notes, phone numbers were removed in 2,000 of 2,000 and complete names in 1,961 (Presidio default) and 1,611 (RAGLeakGuard) of 2,000, yet a full name and a contact channel were both still readable in 1 and 80 notes respectively; which identifiers coincided in those notes beyond these counts is not recorded in the artifacts.

3.5 The public record, as context (quoted as printed; access 2026-10-25; the web pages, the IC3 and FTC PDFs, the ASD fact sheet and the OAIC workbook re-opened 2026-11-02 at typesetting; page numbers are PDF page ordinals, not printed folios)

The leak-to-scam link in this report is an argument supported by the official statements below; it is not a measurement of ours, and no post-breach scam-report spike figure was found in the sources searched as of 2026-10-25 (Optus, Medibank, Latitude). Absence in our search is not proof that none exists.

Australia, scams. National Anti-Scam Centre, *Targeting scams: report of the National Anti-Scam Centre on scams data and activity 2025* (March 2026; combined Scamwatch, ReportCyber, AFCX, IDCARE and ASIC data, de-duplicated): "a combined total of 481,523 reports" (p. 7); "Of these 274,577 reported

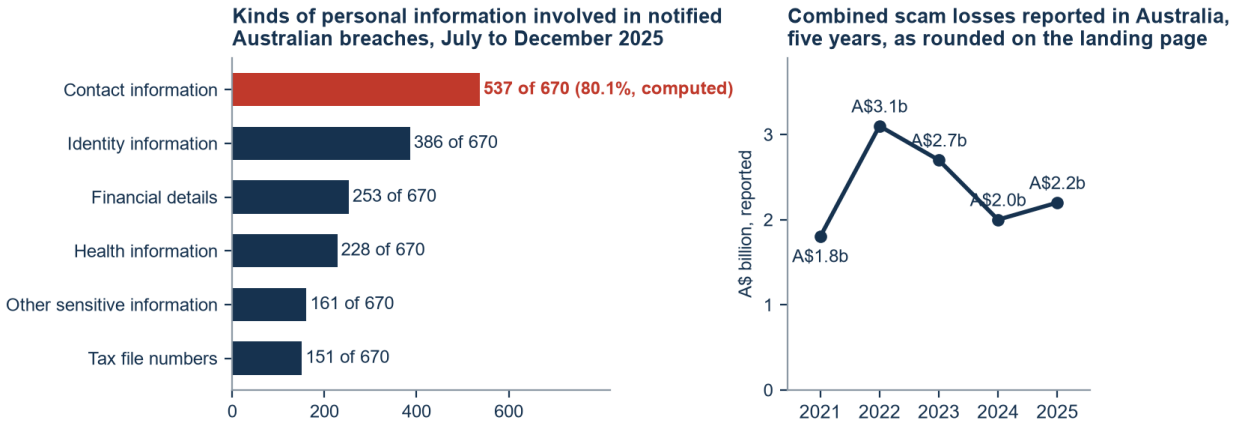
financial losses" (p. 7); "over $2.18 billion (a slight increase of 7.8%)" (p. 7); payment redirection (business email compromise, the fake-invoice redirection) $166.8 million in 2025, up 9.3% from $152.6 million (Table 3, p. 8); phishing $97.6 million, up 15.5% from $84.5 million (Table 3, p. 8); "Scamwatch received 65,361 reports about phishing scams, a decrease of 33.2% compared to 2024. Despite being the most reported scam only 2.3% of people reporting phishing scams reported a financial loss." (p. 36); "Identity theft reports increased by 13.1%." (p. 33); small business: "Small businesses lodged 2,228 reports to Scamwatch in 2025, with 287 reporting financial loss amounting to $9.5 million" and "False billing was the most reported scam type both with and without financial loss. False billing reports from business generally relate to 'payment redirections' also known as 'business email compromise' scams." (pp. 43 to 44); Services Australia "detected and responded to over 14,000 unique agency impersonation scams" (p. 25). The ACCC media release of 30 March 2026: "a reduction in reported scam losses of 29.7 per cent since the peak of $3.1 billion in 2022" (re-read 2026-10-26). **Not quoted on purpose:** a 2025 false-billing total (printed only inside chart images on p. 37, not as text); any cell of Table 6 (false billing by age; the text extraction misaligns its columns and no human has read the table by eye); the live Scamwatch dashboard's 2026 year-to-date figures (no as-at date shown when read on 2026-10-25, and the dashboard has retired "false billing" as a category for 2025 onwards, so nothing in it is like-for-like with the report's false-billing lines).

United States, scams. FBI Internet Crime Complaint Center, *2025 Internet Crime Report*: "1,008,597 complaints" and "$20.877 billion in losses; 26% increase in losses from 2024" (p. 6); business email compromise 24,768 complaints, "$3,046,598,558" (pp. 7 to 8); phishing/spoofing 191,561 complaints, the most reported type, "$215,843,126"; **personal data breach 67,456 complaints, "$1,314,923,988"**, fourth by count and by loss, defined as "A leak/spill of personal data which is released from a secure location to an untrusted environment" (pp. 7 to 8; Appendix B, p.60); government impersonation 32,424 complaints, "$797,943,193" (2024: $405,624,084) (pp. 7 to 8, p. 26); "In 2025, IC3 received more than 22,000 complaints reporting AI-related information. Adjusted losses of these complaints exceed $893 million." (p. 39; descriptor-linked complaints, not losses attributable to any store). IC3 PSA I-091726-PSA, 17 September 2026 (re-read 2026-10-26): "Between January 2025 and July 2026, the FBI's Internet Crime Complaint Center (IC3) received nearly 61,000 complaints of law enforcement or government impersonation scams, with losses totaling more than $1.6 billion." US Federal Trade Commission, prepared statement to the Joint Economic Committee, 25 March 2026 (PDF re-read 2026-10-26): "In 2025, consumers submitted 3 million fraud reports to CSN and reported $15.9 billion in losses." FTC press release, 15 June 2026 (re-read 2026-10-26): "people reported losing a staggering $3.5 billion to imposter scams in 2025"; "nearly $1 billion to business impersonators" and "about $920 million to government impersonators", "up from $866 million and $789 million respectively in 2024". No 2025 Consumer Sentinel Data Book was found on ftc.gov as of 2026-10-25.

Australia, breaches. Office of the Australian Information Commissioner, *NDB Data 1 July 2025 to 31 Dec 2025* (data.gov.au workbook, resource last modified 2026-06-29; cells: the 670 total at Individuals affected!B20, kinds of information at Personal information!B4:B9, sources at Source of breach!B13 with B14:B17, B3 and B18, sectors at Top 5 sectors by source!B4, B10, B16, B21 and B27): 670 notifications; **contact information involved in 537** (80.1%, computed by us from 670), identity information 386 (57.6%), financial details 253 (37.8%), health information 228 (34.0%), other sensitive information 161, tax file numbers 151; malicious or criminal attack 405 (60.4%; cyber incident 253, social engineering or impersonation 88, rogue employee or insider 34, theft 30), human error 194, system fault 35 (the three source categories leave 36 in "currently unknown" and "other"); **health service providers the top sector, 128** (19.1%), finance 83, business and professional associations 72, Australian Government 51, personal services 47. OAIC media release, 6 July 2026 (re-read 2026-10-26): "The OAIC received 1,205 data breach notifications in the 2025 calendar year", "an 8% increase over 2024 (1,112 notifications)", "716 notifications" malicious or criminal, "health service providers the most commonly affected, and accounting for 19% of the total or 225 notifications". The January to June 2025 release gave 532 notifications; 532 +

670 is 1,202, not 1,205, so each period is quoted from its own release and never added; revision after publication is a likely explanation that we have not confirmed. The January to June 2026 statistics were not found as of 2026-10-25 on the OAIC dashboard, publications page or data.gov.au; that is a bounded search result, not proof of non-publication.

The official statements that carry the supply-chain argument (all re-read 2026-10-26 unless marked): Scamwatch, Optus data breach alert (2022, still live): "Scammers will use the data breach and target people in any way that they can. This means you will likely notice an increased number of phishing emails, phone calls, and SMS or social media messages." The exposed data it lists: name, date of birth, phone numbers, email addresses, residential addresses, identity document numbers. Scamwatch, Medibank Private data breach alert (2022): the same two sentences; the data: "Names and addresses, date so [sic] birth, Medicare numbers, policy numbers, phone numbers and some claims data". IDCARE, end-of-2024 review: the most common sources of compromise, ranked, "unknown to the client, followed by data breaches, online shopping scams, telephone phishing, and SMS phishing"; "Scammers often leverage credentials from data breaches or phishing scams"; no count for the data-breach source is printed. Australian Signals Directorate, *Annual Cyber Threat Report 2024–25*, fact sheet for individuals (re-read in the fact-sheet text 2026-10-25): "Individuals are commonly targeted by cybercriminals for financial gain. This can be through scams or through the on-selling of personally identifiable information"; "over 84,700 cybercrime reports"; average self-reported cost for individuals "$33,000 (up 8%)"; top type "Identity fraud (30%)". FBI IC3 PSA, 15 May 2026: "The compromise of sensitive customer or enterprise data could allow threat actors to craft highly sophisticated spearphishing campaigns using real-world context". Scamwatch, fake business invoice alert, 4 April 2024: "Scammers pose as a real business you've recently dealt with. They send fake invoices with changed payment details, so your money ends up with the scammer." and "Scammers make these invoices look real by copying business logos and ABNs".



Left: Office of the Australian Information Commissioner, Notifiable Data Breaches workbook, 1 July to 31 December 2025 (670 notifications; a breach can involve several kinds; the percentage is ours). Right: the Targeting Scams landing-page infographic (Scamwatch, ReportCyber, AFCX, IDCARE and ASIC combined); the report text gives A$2.18 billion for 2025. Public statistics as context: not exposure counts, not a measurement of ours, and no link from any breach to any scam is measured here.

HOW WE MEASURED

Method, and everything wrong with it, stated by us first

The stores. The 2,000-record synthetic Australian dental-clinic knowledge base of Issue #2 (free-text clinical notes, each with name, date of birth, phone, email, Medicare number, address, a complaint line and a plan line; generator imported unchanged, seed 20260801) and the 200 synthetic receptionist calls of Issue #3 (a mixed cohort of 100 Australian and 100 US synthetic patients from the Synthea roster, five scripted scenarios of 40 calls each: booking, reschedule, refill, results, billing; generator imported unchanged, seed 20260914) in three scripted text renderings: formatted (capitals, punctuation, numbers as digits), digits (lower case, no punctuation, numbers as digits, emails verbalised) and spoken (number words). No real person's data was used anywhere.

The kit, three tiers, counted per record. *Deliverable*: full name intact and at least one contact channel (phone, email or postal address) intact. *Core, strict* (the main measure): deliverable, and the provider, and a particular appointment or date cue or an amount. *Core, broad*: deliverable, provider, and any credibility detail (appointment cue, service interval, billing cue, the clinical or service context, or a billing identifier such as a Medicare, Social Security or insurance number). In the clinic store the provider is assumed from database context (one clinic's knowledge base); it is not a text span and can never be redacted, so every clinic kit count is record-plus-context exposure. In the voice store the clinic name is spoken by the agent in every call and is a text span. The date of birth counts as an identifier (a verification cue), not as the kit's date cue. "Service context" means the complaint or condition the visit is about, in the clinic notes sometimes a proposed treatment, never an established billable service.

The redaction. Four scanner configurations: Microsoft Presidio stock defaults (presidio-analyzer 2.2.364, `en_core_web_lg`, spaCy 3.8.16); Presidio with its optional Australian recognisers switched on, both exactly as Issue #3 built them; RAGLeakGuard 0.1.1 `detect()` from source commit `47dedfe5c6adb1134372f0f810e9a7dca4b9d8d0` (an editable install of the local checkout, clean working tree; equivalence to the PyPI distribution was not established) in its default and `--locale au` configurations, run inside its own environment built from the package's `detect` extra (spaCy 3.7.5, numpy 1.26.4, presidio-analyzer 2.2.364, en_core_web_sm 3.7.1); the script probes that environment first and stops if it does not satisfy the package's pins, so the artifact's gate field reads `supported`. Redaction is a **character mask**: the union of every finding at or above the actionable score (0.4), whatever its label, so overlapping and nested detections are handled once and the same way for the counts and for the redacted texts. Each complete occurrence of an element is *visible*, *partial* or *removed*; an element is **intact** if any occurrence is visible, **partial** if none is visible but one is partly visible, **removed** otherwise. Only *intact* counts as surviving in the tiers. Generous to the tool: a Medicare number flagged as a phone number counts as redacted; a first name repeated elsewhere, or a name visible inside an email local-part, is not counted as a surviving name. An in-run consistency check (every intact element's visible occurrence must appear in the redacted text) passed on every record of every configuration, and 23 regression checks pin the behaviour (repeated occurrences, partial remnants, chained and nested overlaps, tier rules, cue classification, annotation completeness, the environment gate).

Three runs, one measurement version. The scans were executed three times; of 2,240 recorded paths in each artifact, 5 vary between the three runs (the run tag and four label tallies on the Social Security element in the digits rendering under the RAGLeakGuard configurations, `US_SSN` against `US_BANK_NUMBER`); every kit count, element state, per-scenario count and redacted text is identical in all three. Three repeats of the same deterministic fixtures show repeatability of the scan, not three independent samples. The first independent review found that the first version of the script annotated only the first occurrence of the billing cue in each billing call; the fix changed no count (no configuration touched the word "bill" in any rendering) and the measurement was rerun as artifact version v2, with the v1 artifacts preserved unchanged and compared path by path.

What is wrong with it, stated first (the twelve caveats, carried from the findings file without softening).

1. **Synthetic and scripted.** Both stores are templated; which kit elements a record holds is decided by the generators and by our cue lists, so the by-construction counts (2,000 of 2,000 notes deliverable before any redaction; 357 with an appointment cue; 80 of 200 calls with a slot) are descriptive only, and no headline is built on them. The redaction results depend on the shape of the identifiers and the surrounding text, and the shapes are real-world formats.
2. **The kit definition is ours.** No regulator or vendor defines a "fake-invoice kit"; the three tiers are stated above so a reader can disagree with the definition and still use the numbers. The strict tier turns on a date cue because no synthetic record carries an amount.
3. **Generous to the tool, on a literal-span endpoint.** Any actionable finding, whatever its label, counts as redaction; an element survives only when a complete annotated occurrence is untouched; a partly covered occurrence is *partial*, never surviving. The other direction follows: partial strings, complementary fragments across occurrences and a reconstructable email name could still help a reader, so a zero strict-kit result means "no intact annotated strict combination remained under this definition", not anonymity, not that the person cannot be contacted, and not that no useful scam material remains.
4. **Model sizes and versions differ by design.** Presidio's default configuration loads `en_core_web_lg` on spaCy 3.8.16; RAGLeakGuard ships on `en_core_web_sm` and ran in its own environment on spaCy 3.7.5, as `detect()` from source commit `47dedfe`. The comparison is "what each tool does in its tested configuration", not a model-size experiment: model and version differences may contribute to the name and address columns, the experiment does not isolate their contribution, and the Medicare and date columns reflect recogniser and post-processing differences that the stored labels do show.
5. **One threshold.** 0.4 is the actionable tier this series has used since Issue #1. The raw artifacts keep the labels but not every sub-threshold score.
6. **No retrieval, no deletion, no audio in this cycle.** The stores are scanned as text. Nothing here measures how an attacker obtains a store; that is the premise of Issues #1 to #3 and of the CVE table in the findings file, not a result. Nothing here measures whether a redaction applied before embedding changes what a vector index or its backups retain; Issue #2 covered index residue, and §6 says what this cycle does and does not establish about the other copies.
7. **The leak-to-scam link is an argument** supported by the official statements in §3.5, not a measurement. No post-breach scam-spike figure was found in the sources searched as of 2026-10-25. This experiment does not establish where the details in any particular scam came from.
8. **Public statistics are dated** (access 2026-10-25; the agent-read pages re-opened 2026-10-26) and taxonomies move: Scamwatch has retired "false billing" for 2025 onwards on its live dashboard (browser read 2026-10-25, not re-checked at drafting); the OAIC half-year and full-year totals differ (revision is a likely but unconfirmed explanation); the FTC's 2025 figures were found only in testimony and a press release, and no 2025 Data Book was found on ftc.gov in the search of 2026-10-25.
9. **Contact identifiers in both stores are fabricated, not reserved.** The voice roster is Synthea-derived (100 AU and 100 US synthetic patients). The code and committed roster support "synthetic fixtures, no live dataset"; they cannot prove that no fabricated email, address or phone number happens to belong to a real person, so the fixtures are never to be contacted or distributed without this caveat.
10. **Scripted renderings, not speech-to-text settings.** The digits and spoken renderings verbalise emails ("kirk dot reinger34 at bigpond dot com"), keep appointment times as digit strings ("monday 315") and change casing and punctuation at the same time; no audio was transcribed. Results per rendering are comparisons of text shapes, not of one vendor setting.

11. **Appointment cue, not a verified appointment date.** "Next Tuesday" and "Tuesday 10:15" are relative or partial cues inside scripted text, and no record carries an amount; the script treats amounts as absent by construction and is not a general invoice-amount detector.
12. **Clinic kits are record-plus-context.** The provider is assumed from database context in every clinic count; the clinic strict and broad tiers state what a reader with access to one clinic's knowledge base could assemble, not what one note contains on its own.

Verification. Every load-bearing public figure was re-read in the downloaded primary document (the IC3 PDF text, the OAIC workbook cells, the Targeting Scams PDF text, the ASD fact sheet) on 2026-10-25, and every page marked as read by a research agent was re-opened by the drafting session on 2026-10-26 before being quoted here. The principal measurement figures were traced claim-by-claim to their JSON fields by the independent review (its §A ledger); the figure checker that gates every draft in this series matches values to artifact fields and flags fragile numbers travelling without their qualifier, and does not judge truth. The three review rounds, their findings and every disposition are recorded in the private findings package; what is published with the report is a reviewed reproducibility export (§7).

WHAT IT MEANS

Consequence, by vertical

The honest frame first. Nothing in this report shows a scam succeeding, and we have still not found a publicly documented vector-database breach in the sources searched as of 2026-10-25 (the tracker's sweep of advisories, press and regulator releases), as we said in Issues #1 to #3. What we can document is three things. First, the official bodies that see the scam reports say, in their own words, that breached personal data is used to target people (Scamwatch after Optus and Medibank; IDCARE listing data breaches second overall among the most common sources of compromise, after "unknown to the client"; the FBI on "spearphishing campaigns using real-world context"). Second, the kinds of data involved in notified Australian breaches are exactly the kit's delivery half: contact information in 537 of 670 breaches notified in July to December 2025 (the latest period located in that search), identity information in 386, with health service providers the most affected sector. Third, our own measurement: after a standard redaction, how much of our defined kit a synthetic record still shows depends on the configured pipeline and the text shape, from 0 of 80 to 60 of 80 scripted spoken-form calls (a count of what remained, so lower is better). We cannot say where any one fake bill's details came from. We can say what a redacted record would still have offered someone who obtained it.

The two halves of the kit. Our kit definition has a delivery half (who you are and how to reach you) and a credibility half (which business, which visit, which appointment, which billing arrangement). The four tested configurations carry recognisers for the delivery half, and in formatted text both tools' masks left no complete strict kit and at most one record in 200 with a full name and a contact channel readable. None of the four carries a recogniser for a provider, a complaint or a billing cue; Presidio's date recogniser does mask the appointment and interval cues, and both frameworks accept added recognisers, so this describes the tested configurations, not what a scanner can be made to do. The measured endpoint is bounded: of the credibility details a note actually holds (the complaint in every note; an appointment cue in 357 of 2,000; an interval cue in 478; a billing cue, "payment plan", "health care card" or "cost grounds", in 648), all were still intact in 2,000 of 2,000 notes under RAGLeakGuard and in 1,071 of 2,000 under Presidio default, with the clinic known from the database the note sits in. Whether that is a problem for your organisation depends on how many names and contact channels the same redaction left beside those details, and that number is the one to check.

Now imagine the invoice names a hospital you visited and refers to a treatment you recognise. The concern is not whether you are careful enough. It is how we reduce unnecessary exposure of the details that could make that message persuasive. This is a hypothetical; nothing in this report demonstrates such a scam or traces where its details came from.

Health. Our synthetic clinic notes each contain a name, a date of birth, a Medicare number, three contact channels, the reason for the visit and the plan; a real clinic's AI assistant, scribe or receptionist may hold some or all of these per record, depending on what it keeps. In our synthetic clinic store, Presidio default left all or part of a Medicare number in 376 of 2,000 notes (221 complete, 155 partial), the complaint fully intact in 1,601, a billing cue ("payment plan", "health care card" or "cost grounds") intact in all 648 notes that carry one, and a complete name in 12; our own tool, in its tested configuration, left 390 Medicare numbers complete and 359 names (remaining-exposure endpoints: fewer intact elements, or fewer Medicare numbers with any readable remnant, is lower exposure on those definitions; the partial component and the denominators carry no direction of their own). Medication and condition details linked to an identifiable patient are health information and therefore sensitive information under Australia's Privacy Act, and a redaction that leaves them does not alter the obligations that attach to holding them. Health service providers were the top sector in the OAIC's notifications in every period we read (128 of 670 in July to December 2025; 225 for the calendar year). For a HIPAA-covered entity or business associate in the United States, electronically stored individually identifiable health information is generally electronic

protected health information, and a PII scan alone does not establish HIPAA de-identification: the Privacy Rule recognises two methods, Expert Determination and Safe Harbor (HHS guidance, read 2026-10-26), and information that has been properly de-identified under one of them is no longer protected health information. The practical question for a practice owner is not "do we redact" but "what does our redaction leave beside the patient's name, and who has checked".

Legal. A law firm's intake agent holds the fact a firm protects hardest: that this person is a client, and roughly what about. Our fixture is a dental clinic, so we did not measure a legal corpus, and the reasoning is by analogy: the credibility half of an intake note is the matter type, the next appointment and the fee arrangement. We did not test legal records. These configurations do not specifically target matter types or fee arrangements; Presidio's date recogniser did mask appointment cues in the tested fixtures. A fake invoice from "your solicitor" is the payment-redirection scam the National Anti-Scam Centre's own alert illustrates with a couple who lost more than $800,000 at property settlement; payment-redirection losses reported in Australia reached A$166.8 million in 2025, and US$3.05 billion in business email compromise losses were reported to the FBI's IC3 (whose report includes some international submissions). Those scams are reported as email-based impersonation or compromise, not as leaked knowledge bases, and we make no claim that any of them began in one. The point for a managing partner is narrower: if the firm's assistant keeps transcripts and the firm's answer to "is personal information removed" is "we run a PII scan", the firm should know which half of the record that scan addresses.

Financial services and brokers. Loan and billing calls are identifier-dense by design. In our scripted spoken-form transcripts, the tested RAGLeakGuard configurations left every spoken phone number (200 of 200), every spoken Medicare number (40 of 40), every Social Security number (19 of 19) and every insurance ID (21 of 21) intact; Presidio default's only touches on the Medicare, Social Security and insurance spans were date guesses that partly covered 20, 19 and 7 of them (and 66 of the 200 spoken phone numbers). These are possible plausibility cues for a fake statement ("they had my policy number"); whether they would pass a victim's check is not something this experiment tested. Government impersonation complaints to the FBI's IC3 carried US$797.9 million in reported losses in 2025; the FBI's combined law-enforcement or government impersonation category drew nearly 61,000 complaints with more than US$1.6 billion in reported losses from January 2025 to July 2026; US consumers reported US$3.5 billion lost to imposter scams in 2025. A broker whose voice agent stores spoken-form transcripts should verify representative masked spoken-form records and record what remains, rather than assume the numbers in them were redacted.

For agencies and builders. If the redaction step in a pipeline is a default recogniser pass inherited from a tutorial, this report measured what two such configurations leave behind on two fixtures. The builder's responsibility is not to pick the perfect scanner; it is to know what the one they shipped is configured to find, at what score, on text written how, and to show the client the redacted record rather than the scan's summary. Section 3.3's two excerpts are what that looks like. If the client cannot see which details remain under the configuration they were given (in our fixture, the complaint and the billing cue under every tested configuration; the appointment cue under RAGLeakGuard but not under Presidio), the client has not been told what was redacted.

My position. I do not believe a patient should have to become a cybersecurity specialist to pay a bill. There are three parties here: the organisation providing the service, the people it hires to build the system, and the person using it. Their responsibilities should reflect what each can control. The organisation commissioning and operating the service should take primary responsibility for protecting its patients and customers. Hiring a developer should not transfer that responsibility to the patient. Builders should test the safeguards they deliver and explain their limits; tool authors should make those limits clear in the documentation people rely on. People can take sensible precautions, but their vigilance should not be the system's last line of protection. My concern is what remains exposed, who can reduce that exposure, and whether the organisation has asked for evidence that its safeguards work. That is why this report

examines what remains after redaction, including when the scanner is our own.

What a redaction does and does not establish (the continuing guidance from Issue #2). A redaction is a text operation on the copy you ran it over. It establishes what that copy shows afterwards, nothing about the original record, the embedding index built from an earlier copy, the backups, the logs, the caches or the platform's own retention. Issue #2 measured index residue after deletion on one database version and found the vectors still in the index file; this cycle measured text after a mask and found the present, annotated clinic credibility elements intact in 1,071 of 2,000 notes under Presidio default and 2,000 of 2,000 under RAGLeakGuard, the tested source installation. Neither result covers the other's layer. An operator who wants to say "the kit is gone" has to say which copy, redacted by which configuration, verified how, and what remains untested. Section 6 gives the verification steps.

WHAT TO DO

Seven steps, in priority order

If you commission the system rather than build it, ask its builder to run these checks and explain the results; you do not need to run Python yourself.

1. **Run this check on one synthetic note shaped like your records, and look at the masked record, not the scan's summary.** It takes a few minutes with Python and Presidio installed. The quick install (`pip install presidio-analyzer` and `python -m spacy download en_core_web_lg`) is unpinned and can resolve different versions from ours, so the labels you see may differ in detail; we ran it with presidio-analyzer 2.2.364, spaCy 3.8.16 and `en_core_web_lg` 3.8.0 on Python 3.12, and exact reproduction uses the measured environment in §7 (`reports/tools/requirements-scamkit.txt`). The note below is `PT-00021` from our synthetic fixture (no real person; fabricated name, number and contacts); it is one of the 221 notes whose Medicare number the default mask left complete. The script masks every finding at or above 0.4, the threshold used throughout this report, and prints the record as it would be stored, before and after one setting.

```
from presidio_analyzer import AnalyzerEngine
from presidio_analyzer.predefined_recognizers import AuMedicareRecognizer

note = ("Patient Wren Dimitriou (DOB 20/02/2007, Medicare 5210 01861 5) routine radiographs, "
        "no new caries identified. Contact 0420 139 923 or wren.dimitriou@bigpond.com. "
        "Address on file: 131 Rathdowne St, Hawthorn VIC 3122. "
        "Booked for a composite restoration next Tuesday.")

def masked(analyzer, text, threshold=0.4):
    """Black out every finding at or above the threshold; show the labels in the gap."""
    hits = [r for r in analyzer.analyze(text, language="en") if r.score >= threshold]
    cover = [set() for _ in text]
    for r in hits:
        for i in range(r.start, r.end):
            cover[i].add(r.entity_type)
    out, i = [], 0
    while i < len(text):
        if not cover[i]:
            out.append(text[i]); i += 1; continue
        j, labels = i, set()
        while j < len(text) and cover[j]:
            labels |= cover[j]; j += 1
        out.append("<" + "|".join(sorted(labels)) + ">"); i = j
    return "".join(out)

analyzer = AnalyzerEngine()                                  # stock defaults
print("BEFORE:", masked(analyzer, note))
analyzer.registry.add_recognizer(AuMedicareRecognizer())     # the one setting
print("AFTER: ", masked(analyzer, note))
```

What we saw when we ran it on 2026-10-26, and what you should see (two lines, rewrapped here for display):

```
BEFORE: <PERSON> (DOB <DATE_TIME>, Medicare 5210 01861 5) routine radiographs, no new caries
        identified. Contact <PHONE_NUMBER> or <EMAIL_ADDRESS|URL>. Address on file: 131 <LOCATION>,
        <PERSON> 3122. Booked for a composite restoration <DATE_TIME>.
AFTER:  <PERSON> (DOB <DATE_TIME>, Medicare <AU_MEDICARE>) routine radiographs, no new caries
        identified. Contact <PHONE_NUMBER> or <EMAIL_ADDRESS|URL>. Address on file: 131 <LOCATION>,
        <PERSON> 3122. Booked for a composite restoration <DATE_TIME>.
```

Before the setting, nothing in the default configuration touched the Medicare number at all (no label, at any score); after it, the Australian Medicare recogniser covers it. Everything else is unchanged by the setting: the name, the date of birth, the phone and the email are masked both times; the complaint ("routine radiographs, no new caries identified") and the house number and postcode are left both times; the suburb is mislabelled as a person; and "next Tuesday" is masked as a date both times, which is why this tool's strict-kit count is 0. Across our 2,000 synthetic notes, this one change took "all or part of a Medicare number still readable" from 376 (221 complete, 155 partial) to 0; on a different

note the number may already be caught by a phone-number guess at the 0.4 floor, so run it on the shape your own records take, a spoken-form transcript if you keep call transcripts, and read what is left on the screen. The measured AU-on configuration in §3.2 enabled all of Presidio's Australian recognisers and an AU-aware phone recogniser; this check enables the Medicare recogniser only, the one that changes the Medicare column. **Our own open-source tool missed the same format**: RAGLeakGuard's Medicare pattern did not match the fixture's spaced numbers and its tested installation left 390 of 2,000 complete; that gap is recorded for review and not yet fixed. This is a label and mask check on one note. It shows what one setting changes; it does not measure a corpus and does not establish coverage of other number shapes.

2. **Ask what survives together, per record.** A per-element summary ("phone numbers removed in 2,000 of 2,000 notes") hides the record where the survivors coincide. For each record, check whether a full name and any contact channel are both still readable; in our synthetic notes that was 1 of 2,000 under Presidio default and 80 of 2,000 under RAGLeakGuard, and in the spoken-form calls 42 and 156 of 200. That per-record number is the one to put in the compliance document, with the tool, the configuration and the text shape beside it.
3. **Treat spoken-form transcripts as unredacted until a scan written for them says otherwise.** Issue #3 showed that neither tested configuration recognised a spoken phone number as a phone number; this issue shows the consequence for the kit (counts of what remained, so lower is better): under RAGLeakGuard's tested installation, a full name and a contact channel were still readable in 156 of 200 scripted spoken-form calls, 60 of 80 kept a complete strict kit, and every spoken Medicare, Social Security and insurance number was intact. If your platform's speech-to-text writes numbers as words, verify representative masked spoken-form records and record what remains, rather than relying on a scanner's summary; the four configurations we tested left the spoken numbers intact or only partly covered.
4. **Decide what a free-text record needs to hold at all.** In our test the billing cues and most of the service context survived because none of the four tested configurations carries a recogniser for them (Presidio's date recogniser did cover the appointment and interval cues and parts of two service templates), and the appointment cues survived under RAGLeakGuard because its date post-filter drops them; added recognisers are one answer, and both frameworks accept them. Our recommendation, and it is a recommendation rather than a measured result, is data minimisation for the AI copies: keep the booking, the plan and the payment status in the system built to hold them, and do not carry the sentence that contains them beside the patient's name into a knowledge base, a transcript store or an agent memory that does not need it. Structured fields can hold the same identifying combination, so restructuring on its own removes no exposure; what removes it is not making the copy. This applies to copies you do not need, within whatever retention your records obligations require, never to the source record itself. Redact before you embed, on the copy that will be embedded, and keep the redacted copy as the evidence of what was embedded.
5. **Know your threshold and your labels.** The actionable floor matters: in the synthetic note shown in §3.3, the Medicare number went only because a phone-number guess landed at exactly 0.4, the floor. A pipeline that raised its floor to 0.5, or kept only "high confidence" findings, would have left that span. Record the threshold with the result, and read the labels: a number removed as a date or a phone number does not establish reliable coverage of other numbers in the same shape (in our fixture, 221 of 2,000 Medicare numbers stayed complete under the same configuration).
6. **Say which copy you redacted, and what you did not test.** A redaction establishes the state of the copy it ran over. The original record, an index embedded from an earlier copy, backups, logs and the platform's retained transcripts are separate questions with separate evidence (Issue #2 for index residue; Issue #3 for platform retention defaults). Write down, per store, which copy was redacted, by which configuration, verified by whom, and what remains untested. A clinic that can say those

sentences to a regulator is in a different position from one that cannot.

7. **Prepare the investigation now, not after the first wave.** If convincing invoices reach your customers, an investigation may examine the stores that held their details. The cheapest sentence in security is the one you never have to write: "We are writing to inform you". The second cheapest is the one you can write because you checked: "Our records were redacted with [tool, version, configuration], at threshold 0.4, on [date]; here is a redacted record; here is what the redaction does not cover." Items 1 to 6 produce that sentence.

APPENDIX

Methodology detail, reproduction and sources

Reproduce it. A reviewed reproducibility export is published with the report, as Issue #3 did with its cleaned findings copy: the script, the pinned environments, the regression checks, the three v2 raw run artifacts (and the preserved v1 artifacts) and a cleaned findings copy with the verification log. The working findings file and the review records stay in the private archive until a disclosure review clears what is released. Two environments are required, because the Presidio configurations were measured on the Issue #3 pins (spaCy 3.8.16, numpy 2.4.6) while RAGLeakGuard's `detect` extra pins spaCy below 3.8 and numpy below 2; the script probes the RAGLeakGuard environment before scanning and stops if it does not satisfy those pins. From the repository root, Python 3.12:

```
py -3.12 -m venv reports/tools/scamenv
reports/tools/scamenv/Scripts/python.exe -m pip install -r reports/tools/requirements-scamkit.txt
py -3.12 -m venv reports/tools/rlgenv
reports/tools/rlgenv/Scripts/python.exe -m pip install -e "<RAGLeakGuard checkout root>[detect]"
reports/tools/rlgenv/Scripts/python.exe -m pip install -r reports/tools/requirements-rlg.txt
reports/tools/scamenv/Scripts/python.exe reports/findings/src/scam_kit.py run4
```

(On macOS substitute `python3.12 -m venv` and `.../bin/python`.) The RAGLeakGuard checkout must be at commit `47dedfe5c6adb1134372f0f810e9a7dca4b9d8d0`, the commit the tables were measured at; the script records the commit and dirty state it actually scanned with. The `run4` tag keeps a validation rerun from overwriting the three measured artifacts. The product's dependency ranges are not an exact lock, so a fresh resolver may pick other compatible versions: a rerun reproduces a supported setup, not necessarily the exact resolved versions recorded in the artifacts. Regression checks: `reports/tools/scamenv/Scripts/python.exe -m unittest reports/findings/src/test_scam_kit.py` (23 checks).

What the artifacts hold. Per store and per configuration: records still deliverable after redaction, records still holding each kit tier, per-scenario counts, each element's intact / partial / removed states, the labels the tool put on each element it touched, per-template service states, the per-record identifier histogram, the in-run consistency flag, the Presidio environment, and for RAGLeakGuard a batch count and a within-configuration equality flag per configuration plus one shared final environment snapshot from the last batch (commit, dirty state, package versions, the gate result); individual batch environments and the initial gate probe were not retained in v2, and the amended script saves them for future runs only. Verbatim redacted texts are kept as texture. Three runs; the five varying paths are listed in §4.

What happened after Issue #2 (dated note, re-checked at drafting and again at typesetting on 2 November 2026). Issue #2 reported that on ChromaDB 1.5.9, deleting 100 records left all 100 tested vectors in the HNSW index file and that `chroma vacuum` did not remove them, and filed it as `chroma-core/chroma#7662` on 31 August 2026 with a reproducible script. An outside contributor, SiluPanda, reproduced the result independently within eight days and wrote documentation pull request #7693. After the maintainer asked on 12 October 2026 where the "vacuum equals secure delete" expectation came from, the contributor narrowed the pull request to Chroma's Delete Data page on 13 October, and we confirmed the same day that the revised wording addresses our documentation concern, pointing to the page's own sentence "The embeddings, documents, and metadata associated with each item will be deleted". **As of 2 November 2026 the pull request is proposed and unmerged** (open; last activity 21 October 2026, the contributor asking the maintainer again; no formal maintainer review object), issue #7662 is open (last updated 8 September 2026), and both `main` and the live Delete Data page still carry the original sentence. A documentation change, if merged, implements no erasure mechanism and validates no claim of Issue #2 beyond the wording it corrects; the behaviour was measured on local Chroma 1.5.9 and says nothing about newer releases, managed services or backups; there has been no Chroma release since 1.5.9 (5 May 2026). Related work, not a rerun and not audited in this cycle: Culatana and Li (arXiv:2609.19456, September 2026) describe hnswlib's `mark_deleted` path, the library

Chroma uses, scoring deleted vectors during traversal in general; Chroma pull request #7921 (October 2026, closed unmerged) describes persisted HNSW data surviving collection deletion when the segment was evicted. Neither reproduces the Issue #2 experiment and neither changes it. We report the record without inferring motives, expertise, negligence or endorsement from wording choices or merge decisions. If the pull request is still pending at publication, the report will say so; it is not held for a merge.

Full source list (every public figure primary-source verified, with access dates; nothing marked secondary in the tracker is cited): National Anti-Scam Centre, *Targeting scams: report of the National Anti-Scam Centre on scams data and activity 2025*, March 2026, PDF (read 2026-10-25) and the ACCC media release of 30 March 2026 (re-read 2026-10-26) · FBI Internet Crime Complaint Center, *2025 Internet Crime Report*, PDF (read 2026-10-25); IC3 PSA I-091726-PSA, 17 September 2026, and the PSA of 15 May 2026 (re-read 2026-10-26) · US Federal Trade Commission, prepared statement to the Joint Economic Committee, 25 March 2026, PDF, and press release of 15 June 2026 (re-read 2026-10-26) · Office of the Australian Information Commissioner, *NDB Data 1 July 2025 to 31 Dec 2025* workbook on data.gov.au (cells read 2026-10-25); OAIC media release, 6 July 2026 (re-read 2026-10-26); OAIC blog, 4 November 2025 (agent read 2026-10-25) · Australian Signals Directorate, *Annual Cyber Threat Report 2024–25*, fact sheet for individuals (read 2026-10-25) · Scamwatch alerts: Optus data breach scams (2022), Medibank Private data breach (2022), fake business invoice scams (4 April 2024) (re-read 2026-10-26) · IDCARE, end-of-2024 review (re-read 2026-10-26) · Presidio source as installed (presidio-analyzer 2.2.364) and its `default_recognizers.yaml` at tags 2.2.359 and 2.2.364 (the four Australian recognisers `enabled: false`); the project's documentation now lives at presidio.dataprivacystack.org, so the cited source is pinned to the package version, not to current stewardship · RAGLeakGuard source, commit `47dedfe` (github.com/Agenvana/RAGLeakGuard) · chroma-core/chroma issue #7662 and pull requests #7693 and #7921 · US Department of Health and Human Services, *Guidance Regarding Methods for De-identification of Protected Health Information in Accordance with the HIPAA Privacy Rule* (read 2026-10-26) · Office of the Australian Information Commissioner, *Australian Privacy Principles guidelines*, Chapter B (key concepts: health information, sensitive information; read by the independent reviewer 2026-10-26) · Culatana and Li, arXiv:2609.19456 · the findings package with its verification log (`reports/findings/FINDINGS-2026-10.md`; the three independent review rounds are in the private working archive, and the published export is the reviewed copy).

Primary locators for the public figures. Targeting Scams 2025 PDF, https://www.scamwatch.gov.au/system/files/targeting-scams-report-2025.pdf (PDF page ordinals as cited) · ACCC media release, 30 March 2026, https://www.accc.gov.au/media-release/continued-action-critical-to-combat-fraud-as-annual-scam-losses-exceed-2-billion · Targeting Scams landing page (five-year loss chart, rounded as displayed), https://www.scamwatch.gov.au/research-and-resources/targeting-scams-report · IC3 2025 Internet Crime Report PDF, https://ic3.gov/AnnualReport/Reports/2025_IC3Report.pdf · IC3 PSA, 17 September 2026, https://www.ic3.gov/PSA/2026/PSA260917 · IC3 PSA, 15 May 2026, https://www.ic3.gov/PSA/2026/PSA260515 · FTC testimony, 25 March 2026, https://www.ftc.gov/system/files/ftc_gov/pdf/ftc-testimony-jec-hearing-on-the-rising-scam-economy.pdf (PDF p.3, printed p.2) · FTC press release, 15 June 2026, https://www.ftc.gov/news-events/news/press-releases/2026/06/ftc-data-show-people-reported-losing-3-point-5-billion-imposter-scams-2025 · OAIC NDB workbook, July to December 2025, https://data.gov.au/data/dataset/5781dc17-2ad0-4dd1-bced-01c544943ce3/resource/e14c521b-0966-42cf-849b-0ef1214e8903/download/ndb-data-1-july-2025-to-31-dec-2025.xlsx (cells as cited in §3.5) · OAIC media release, 6 July 2026, https://www.oaic.gov.au/news/media-centre/data-breach-notifications-increase-to-all-time-high-in-2025,-new-ndb-stats-show · OAIC blog, January to June 2025, https://www.oaic.gov.au/news/blog/latest-notifiable-data-breach-statistics-for-january-to-june-2025 · OAIC APP guidelines Chapter B, https://www.oaic.gov.au/privacy/australian-privacy-principles/australian-privacy

-principles-guidelines/chapter-b-key-concepts · ASD fact sheet for individuals, https://www.cyber.gov.au/sites/default/files/2025-10/Annual%20Cyber%20Threat%20Report%202024-25%20factsheet%20for%20individuals.pdf · Scamwatch alerts: https://www.scamwatch.gov.au/about-us/news-and-alerts/browse-news-and-alerts/optus-data-breach-scams, https://www.scamwatch.gov.au/about-us/news-and-alerts/browse-news-and-alerts/medibank-private-data-breach, https://www.scamwatch.gov.au/about-us/news-and-alerts/scam-alert-fake-business-invoice-scams · IDCARE year review, https://www.idcare.org/latest-news/the-year-that-was-a-record-year-for-financial-losses-to-cybercrime · HHS de-identification guidance, https://www.hhs.gov/hipaa/for-professionals/special-topics/de-identification/index.html · Presidio default recognisers at 2.2.359, https://raw.githubusercontent.com/microsoft/presidio/2.2.359/presidio-analyzer/presidio_analyzer/conf/default_recognizers.yaml. Absence statements in this report are bounded to the sources searched as of 2026-10-25; a later discovery would update the dated statement, not invalidate the bounded search.

About. *The AI Data Security Report* is a monthly, methods-open report on where AI pipelines actually leak data. Measured, not guessed. Author: **Wen-Chia "Belle" Chang** (hybrid form, per the Issue #1 attribution decision; LinkedIn byline stays Belle Chang). The author's work on data-layer privacy for AI systems is **patent pending** (US provisional filed 18 July 2026; a filing status, not a validation of this experiment or a claim that any product prevents fraud).

Issue #1 (July 2026), *"Your AI's Privacy Filter Speaks American. It Missed 1 in 3 Australian IDs."* Issue #2 (August 2026), *"We Asked an AI Database to Delete 100 Patients. All 100 Were Still There."* Issue #3 (September 2026), *"We Audited Five Voice-AI Platforms. Three Document Recording On by Default. Four Quick-Starts Never Mention Retention."*